

內部稽核機密資
料

(PROPRIETARY

&

CONFIDENTIAL)

API SECURITY AUDIT

度
安
全
技
術
評
估

專案名稱
(Project):

vAmPI
Scan

目標位址
(Base
URL):
http://

vampi:

5000

稽核編號

(Audit ID):

#14

生成日期

(Date):

2026-02-27

16:01:29

1. 執行摘要 (Executive Summary)

本報告總結了對端點 `http://vampi:5000` 進行自動化安全掃描的結果。本次稽核專注於檢測 **OWASP API Security Top 10 (2023)** 所列出的關鍵威脅，包括權限控制缺失、數據暴露與頻率限制等風險。

在本次評測中，系統共掃描 **7** 處可能的攻擊媒介點。具體漏洞統計如下表所示：

風險類別	嚴重等級 (Severity)	發現數量 (Count)	優先級 (Priority)
High-Risk Findings	高 (High)	3	立即修補 (Urgent)
Medium-Risk Findings	中 (Medium)	4	計劃性修補 (Planned)
Total Vulnerabilities	-	7	-

* 評等參考標準：基於漏洞的可利用性 (Exploitability) 與對業務數據的潛在影響 (Impact) 進行綜合評分。

2. 稽核發現詳情 (Audit Findings)

1. Mass Assignment (批量賦值)

MEDIUM

風險 API : `POST /users/v1/login`

A. 業務影響評估 (Business Impact)

攻擊者可以通過注入非法欄位來提升權限或破壞數據。

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): `Status: 200 with extra fields`

C. 修復建議與對策 (Remediation)

GPT 修復指南： 使用數據傳輸物件 (DTO) 並採用『允許清單 (Allow-list)』機制。僅將明確定義的欄位綁定到資料庫模型。

開發者最佳實踐： 在 FastAPI 中，使用 Pydantic 模型嚴格限制輸入欄位，切勿直接使用請求中的 dict 更新資料庫。

2. Broken Function Level Authorization (BFLA)

HIGH

風險 API : `GET /users/v1/_debug`

A. 業務影響評估 (Business Impact)

Allowing low-privilege users to access administrative functions.

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): `Status: 200`

C. 修復建議與對策 (Remediation)

GPT 修復指南： 實施嚴格的角色存取控制 (RBAC)。確保在調用敏感功能前，後端必須驗證用戶的權限等級，而非僅僅檢查是否登錄。

開發者最佳實踐： 採用『最小權限原則』，並在 API 網關或控制層實施統一的權限攔截器。

3. Broken Function Level Authorization (BFLA)

HIGH

風險 API：GET /users/v1

A. 業務影響評估 (Business Impact)

Allowing low-privilege users to access administrative functions.

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): Status: 200

C. 修復建議與對策 (Remediation)

GPT 修復指南： 實施嚴格的角色存取控制 (RBAC)。確保在調用敏感功能前，後端必須驗證用戶的權限等級，而非僅僅檢查是否登錄。

開發者最佳實踐： 採用『最小權限原則』，並在 API 網關或控制層實施統一的權限攔截器。

4. Excessive Data Exposure (過度資料洩漏)

MEDIUM

風險 API：GET /users/v1/_debug

A. 業務影響評估 (Business Impact)

敏感資訊 (如密碼雜湊、個人私隱) 洩漏給了前端用戶。

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): Exposed fields: ['password']

C. 修復建議與對策 (Remediation)

GPT 修復指南： 實施回應過濾。確保 API 回傳的數據僅包含前端顯示所需的最小欄位，避免直接回傳整個資料庫物件。

開發者最佳實踐： 在後端模型中將敏感欄位標記為隱藏，或使用產出的 Schema 過濾敏感數據。

5. Broken Object Level Authorization (BOLA)

HIGH

風險 API：GET /users/v1/admin

A. 業務影響評估 (Business Impact)

用戶可以存取或修改不屬於自己的數據物件。

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): Status: 200

C. 修復建議與對策 (Remediation)

GPT 修復指南： 實施物件級屬主校驗。在 API 處理請求時，應檢查輸入的識別碼 (如 {id}) 是否確實屬於當前登錄用戶。

開發者最佳實踐： 避免使用可預測的 ID (如遞增數字)，建議使用隨機的 UUID，並始終在 SQL 語句中加入 user_id 過濾條件。

6. Mass Assignment (批量賦值)

MEDIUM

風險 API：POST /users/v1/register

A. 業務影響評估 (Business Impact)

攻擊者可以通過注入非法欄位來提升權限或破壞數據。

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): Status: 200 with extra fields

C. 修復建議與對策 (Remediation)

GPT 修復指南： 使用數據傳輸物件 (DTO) 並採用『允許清單 (Allow-list)』機制。僅將明確定義的欄位綁定到資料庫模型。

開發者最佳實踐： 在 FastAPI 中，使用 Pydantic 模型嚴格限制輸入欄位，切勿直接使用請求中的 dict 更新資料庫。

7. Lack of Resources & Rate Limiting

MEDIUM

風險 API： `POST /users/v1/login`

A. 業務影響評估 (Business Impact)

API 容易遭受暴力破解 (Brute-force) 或拒絕服務 (DoS) 攻擊。

B. 技術根因分析 (Technical Analysis)

基於掃描器偵測到的異常狀態碼或特徵字串判定。

證據 (Evidence): `Processed 15 burst requests with no 429 response`

C. 修復建議與對策 (Remediation)

GPT 修復指南： 實施 API 頻率限制 (Throttling)。針對特定的端點 (如 Login) 設定每分鐘的最大請求次數。

開發者最佳實踐： 使用 Redis 實現令牌桶或漏桶算法，或利用 API 網關 (如 Kong, Nginx) 的頻率限制模組。

3. 合規性說明 (Compliance)

本報告之基準參考以下國際通用安全框架：

- **OWASP API Security Top 10 (2023)**：專注於 Web API 的通用漏洞。
- **GDPR 數據保護規範**：涉及 Excessive Data Exposure 相關項目。
- **NIST 網路安全框架**：針對風險評估與緩解策略之對應。